Introduktion til software sikkerhed Del 3

Del 3 – Sikkerheds mål.

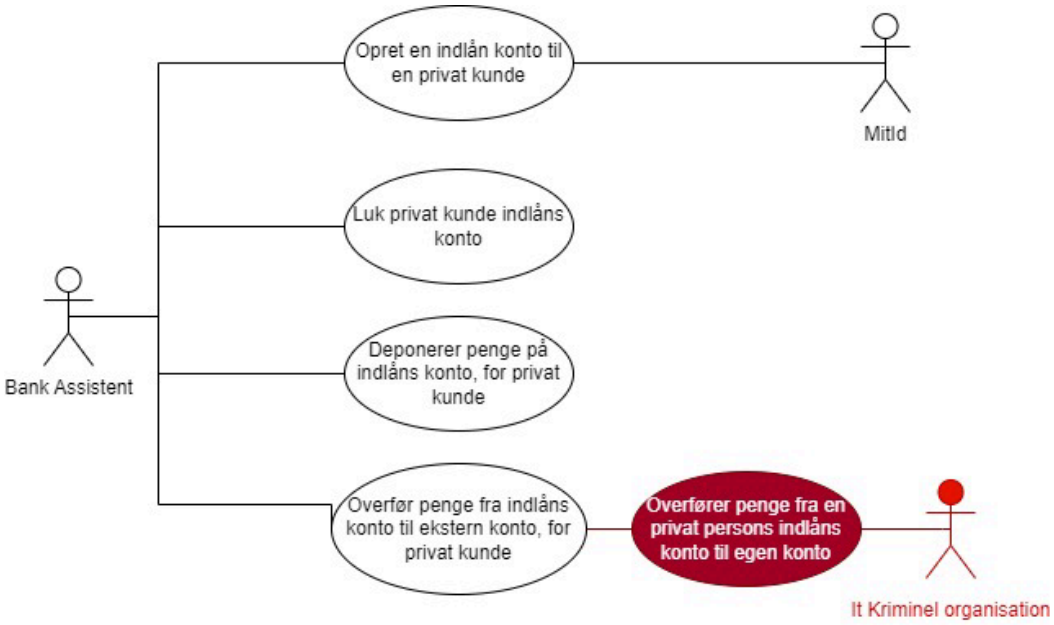
Af Martin Edwin Schjødt Nielsen

University College

Sikkerheds mål

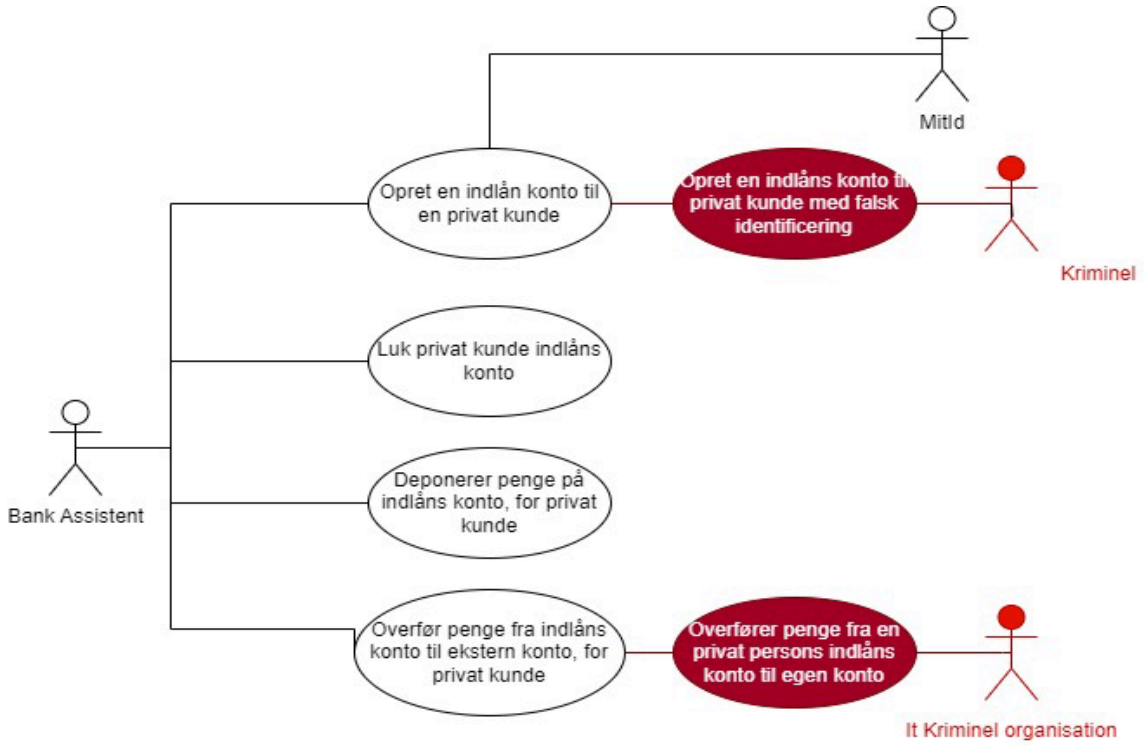
Sikkerhedsmål etableres ud fra systemmål. Sikkerhedsmålene beskriver overordnet og abstrakt, hvad der ikke må ske i systemet, og de udtrykkes som misbrugstilfælde. Systemmål viser systemets forretningsmæssige formål, mens misbrugstilfælde viser, hvordan disse mål kan kompromitteres eller misbruges. Med andre ord identificerer misbrugstilfælde, hvad der potentielt kan skade den forretning som IT systemet understøtter.

Fremgangsmåden er at tage udgangspunkt i et brugstilfældediagram (Systemmålene). Diagrammet fungerer som omdrejningspunktet for en brainstormingsession, hvor målet er at identificere så mange trusler som muligt mod systemmålene og de involverede aktiver. Ved at anvende CIA-modellen kan trusler påtegnes på brugstilfældediagrammet som misbrugstilfælde, og den fjendtlige aktør, der misbruger systemet, kan identificeres. Figur 1 viser et diagram, hvor et misbrugstilfælde er markeret med rød farve.



Figur 1 Brugstilfælde diagram med misbrugstilfælde

Brainstorming-processen fortsætter, så længe tiden tillader det, og behøver ikke nødvendigvis at begrænse sig til cybertrusler mod systemet. Trusler, der tager udgangspunkt i den fysiske verden, kan også inddrages. For eksempel kan man overveje en kriminel, der forsøger at oprette en indlånskonto med falsk identifikation, som illustreret i Figur 2.



Figur 2 Misbrugstilfælde som ikke er et cyber angreb

Med blot få brugstilfælde kan brainstorming og identificering af misbrugstilfælde hurtigt tage overhånd og blive en lang, uoverskuelig proces. Det er derfor vigtigt, at det udføres iterativt. For hvert identificeret misbrugstilfælde på diagrammet bør der udarbejdes en beskrivelse. Figur 3 viser et eksempel på dette.

misbrugstilfælde 2: Opret en indlånskonto til private kunder falsk identificering

Tilknyttede brugstilfælde Nr. 14

Forudsætning: Den ondsindede aktør har adgang til falsk pas eller kørekort

Den kriminelle henvender sig til bankassistenten for at få oprettet en privat indlånskonto og oplyser følgende falske oplysninger: Fornavn, Mellemnavn (Hvis aktuelt), Efternavn, Køn, CPR-nummer, Bopæls gadenavn, Bopæls hus el. lejlighedsnummer, samt foreviser falsk pas eller kørekort til bankassistenten.

Foranstaltning: Da MitId skal benyttes til at bekræfte kontooprettelsen, fungere denne som 2 faktor identificering, og fungerer derfor som foranstaltning mod oprettelse af private indlåns konto med falsk identificering i form af forfalsket pas eller kørekort.

Bemærkning: Foranstaltningen mod denne trussel opretholdelses af MitId som agerer 3 part ift. systemet. Hvis MitId på et tidspunkt ikke længere indgår i processen for oprettelse af indlåns konto til private, vil denne trussel blive aktuel.

Figur 3 Misbrugstilfælde

Her er det værd at bemærke, at en procesmæssig foranstaltning mod misbrugstilfældet er noteret**. Dette er ikke et krav**, men det kan være en god idé, da det viser eksterne afhængigheder for sikkerheden. Det er dog kun procesmæssige foranstaltninger, der kan noteres, ikke tekniske. Det høje abstraktionsniveau, som tager udgangspunkt i systemmål (og dermed forretningsmål), betyder, at de beskrevne trusler er

konceptuelle trusler mod forretningen. Senere i trusselsmodelleringen kan de konkrete tekniske trusler og angrebsmodeller udledes og omsættes til konkrete sikkerhedskrav, der skal implementeres for at imødegå alle sikkerhedsmål.

Ejer af aktiver, forretningsprocesser og interessenter.

Alle misbrugstilfælde tager udgangspunkt i et eller flere brugstilfælde, der understøtter forretningens mål med systemet. Dette betyder, at aktiver, som kan blive kompromitteret, indebærer en risiko for den del af virksomheden, der 'ejer' aktivet. Alle ejere af aktiver bør deltage i udarbejdelsen af misbrugstilfælde, da de har dyb indsigt i domænet og derfor kan bidrage til en definition af, hvornår et aktiv er blevet kompromitteret. Derudover kan der være interessenter, som ikke nødvendigvis ejer et aktiv, men som er en del af den forretningsproces, hvor aktivet anvendes, og derfor også kan bidrage til definitionen af, hvornår et aktiv er kompromitteret. Endelig skal det nævnes, at ejeren af en forretningsproces og et aktiv ikke nødvendigvis er den samme person. Ejeren af en forretningsproces bør også deltage. I praksis kan der være en del detektivarbejde med at finde alle ejere af aktiver og forretningsprocesser, især i større virksomheder. Det kan også forekomme, at systemejeren og ejeren af et aktiv ikke tilhører samme virksomhed.

Definition af sikkerhed for et givet system

Med udarbejdelsen af brugstilfælde er systemet og målet for dette defineret. Når misbrugstilfælde derefter udledes fra denne definition, bliver sikkerheden defineret i kontekst til systemet. Dette skaber overblik, og al sikkerhed begynder med overblik. Man kan forestille sig, at man bliver bedt om at sikre et hus mod indbrud. Så er man nødt til at vide, hvordan huset ser ud, samt hvor alle vinduer og døre er placeret. Det samme gør sig gældende for software sikkerhed. Hvis man ikke ved, hvad der kan gå galt, kan man heller ikke sikre et system.